

Physical Security Policy

Version: v1.0 ADOPTED **Adopted:** 2026-07-21 by Sami Ben Chaalia (Security Officer) **Date:** 2026-07-21 **Owner:** Security Officer (Sami Ben Chaalia) **Framework mapping:** SOC 2 CC6.4 (Restricts physical access) · HIPAA §164.310 Physical Safeguards · ISO 27001 A.7 (Physical + environmental security) **Companion documents:** Vendor Management Policy §3 · Access Control Policy · BC/DR Policy §5.8.

1. Purpose

Document RailCall's physical security posture honestly. Short by design — the honest answer for a fully-remote two-person team with no owned physical infrastructure is much shorter than a template borrowed from a company with data centers.

2. Scope

- **Cloud infrastructure** (Render for the gateway, DigitalOcean for the VPS + snapshots, Cloudflare for edge) — physical security is 100% these vendors' responsibility.
 - **Operator workstations** (Sami's laptop, Pat's laptop) — physical security is the operator's own responsibility, with baseline requirements below.
 - **Physical secret backups** (paper copies of the issuer signing seed + 1Password emergency kit) — kept in Sami's personal safe.
-

3. RailCall does not operate any physical infrastructure

Stated explicitly so absence of controls cannot be misread as a gap. RailCall does not own or operate:

- Any data center, colocation cage, or server room.
- Any office premises with servers on-prem.
- Any customer-facing physical hardware, appliance, or device.

Every byte of RailCall-controlled infrastructure runs on someone else's physical infrastructure. This is architectural, not accidental — a two-person team with a local-first product doesn't need physical infrastructure to serve the product.

4. Cloud provider physical controls (inherited)

We rely on the following providers' physical security programs. Reviewed annually per Vendor Management Policy §7.

Provider	Physical posture (as published)	Where it applies to us
Render	SOC 2 Type II, hosted on AWS underneath — inherits AWS data-center physical controls (24x7 armed guards, biometrics, media handling, environmental)	Gateway service + managed Postgres
DigitalOcean	SOC 2, SOC 3, ISO 27001 — DC access controls documented in their trust portal	VPS <code>157.230.177.45</code> + weekly snapshots
Cloudflare	SOC 2 Type II, ISO 27001 — global edge with physical DC controls per their trust page	DNS + edge cache for railcall.ai
GitHub	Microsoft's SOC/ISO/PCI posture applies	Source code + release artifacts
Stripe	SOC 1/2 Type II, PCI-DSS Level 1	Payments infrastructure
Anthropic	SOC 2 Type II	Probo dev-only LLM calls

Compliance transfer: any customer requiring physical DC certifications gets the answer "we inherit them from our cloud providers; their SOC reports are available under NDA on request; see Vendor Management §3 for the full list."

5. Operator workstation baseline

Every operator laptop must maintain:

- **Full-disk encryption enabled** (macOS FileVault, Windows BitLocker, Linux LUKS). No exceptions. FileVault on Sami's laptop is verified quarterly.
- **Screen lock $\leq$ 5 min idle timeout** with password/biometric to unlock.
- **OS + browser + relevant apps updated** within 30 days of vendor patch release for security updates.
- **No unattended access in public spaces** — laptop stays with the operator or is physically locked away.
- **Loss/theft = immediate incident** (BC/DR §5.8): remote wipe if the box supports it, credential rotation, 1Password vault re-key.

Not enforced by any device management system today (no MDM at team size 2). Enforced by the operator's own discipline + the credential rotation runbook that makes a stolen laptop's contents

rotate to worthless within hours.

6. Physical secret storage

The one exception to §3 — RailCall holds two physical items whose loss would be operationally serious:

- **Issuer signing seed paper backup** — printed on plain paper, sealed in an envelope, stored in Sami's personal fireproof safe. Location known only to Sami; sealed backup instructions (envelope location + safe combination) shared with Pat via 1Password emergency kit.
- **1Password emergency kit** — the recovery-code paper for Sami's 1Password vault. Same safe.

Both are needed for recovery only in scenarios where digital backups are also unrecoverable (§BC/DR §5.7, §5.8). Reviewed annually — verify both still exist + are legible + the safe still opens.

7. Related documents

- **Vendor Management Policy §3** — the cloud providers whose physical controls we inherit.
- **Access Control Policy §6** — the operator inventory whose devices §5 applies to.
- **BC/DR Policy §5.7, §5.8** — the recovery scenarios that require §6 physical backups.
- **Confidentiality Policy §2** — the SECRET class classification of the physical seed backup.